

# Comprehensive Study Guide & Question Bank

Complete Core Concepts, Technical Architecture Diagrams & Accenture MCQs with Detailed Explanations

## MODULE 1: CLOUD NETWORK SECURITY & PERIMETER CONTROLS

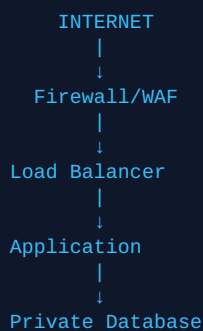
### 1. Cloud Network Security



**Definition:** Cloud Network Security is the set of controls used to protect communication between users, applications, servers, databases, and other cloud resources.

**In simple words:** Cloud Network Security = Controlling and protecting network traffic inside and outside the cloud.

#### Traffic Flow Architecture:



#### The objective is to ensure:

- Only legitimate traffic enters.
- Unauthorized traffic is blocked.
- Sensitive resources aren't directly exposed.
- Internal communication is protected.

## 2. Firewall



A firewall is a security control that monitors and controls network traffic according to predefined rules.

### Example Traffic Filtering:

```
Internet
|
↓
Firewall
|
+---- HTTPS → ALLOW
|
+---- SSH   → Restricted
|
+---- Unknown traffic → BLOCK
```

A firewall can inspect things such as: Source IP, Destination IP, Port, Protocol, and Traffic direction.

#### Example Rules:

- Allow: TCP + Port 443 (Port 443 → HTTPS)
- Block: TCP + Port 23 (Port 23 → Telnet)

## 3. Inbound vs Outbound Traffic



**Inbound (Ingress):** Traffic coming into your resource.

**Outbound (Egress):** Traffic leaving your resource.

```
Internet
|
↓
Cloud Server
```

```
Cloud Server
|
↓
Internet
```

**Remember: Inbound = IN | Outbound = OUT**

## 4. Security Group



A Security Group is a virtual firewall associated with cloud resources (e.g., AWS EC2 instances, ENIs).

```
EC2
|
Security Group
|
+-----+-----+
|         |         |
TCP 443   TCP 22
ALLOW    Restricted
```

**Rule Definitions:** HTTPS → Allow | SSH → Allow only from trusted IP | Other → Deny (Implicit Deny).

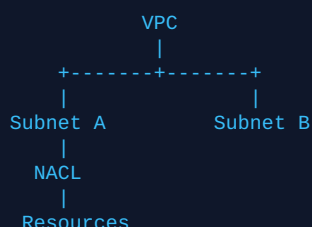
📌 Interview point: Security Groups are commonly associated with instance/resource-level network access control. AWS documents security groups as an important customer-configured security control under the shared responsibility model.

## 5. Network ACL (NACL)



Network ACL (Access Control List) controls traffic at the subnet/network level.

**Hierarchy: Security Group → Resource-level control | Network ACL → Subnet-level control**



## 6. Security Group vs Network ACL



This comparison is critical for certification and technical interviews:

| Feature         | Security Group                                         | Network ACL                                                |
|-----------------|--------------------------------------------------------|------------------------------------------------------------|
| Scope           | Resource / Instance level (ENI)                        | Subnet level                                               |
| Purpose         | Control traffic to/from specific resources             | Control traffic entering/leaving subnets                   |
| Associated With | EC2, RDS, Lambda, Network Interfaces                   | VPC Subnets                                                |
| Statefulness    | <b>Stateful</b> (Return traffic automatically allowed) | <b>Stateless</b> (Inbound & outbound evaluated separately) |
| Rules Supported | Allow rules only (Implicit deny)                       | Allow and Deny rules (Numbered order)                      |
| Granularity     | More granular                                          | Broader                                                    |

**⚠ Important Trap: Security Group is Stateful (If inbound is allowed, outbound response is automatically allowed). NACL is Stateless (Inbound and outbound rules must be explicitly configured).**

## 7. Network Segmentation & Subnet Architectures



Network segmentation divides a network into smaller isolated sections to reduce the attack surface and limit lateral movement.

### ✗ Bad Design (Flat Network):

```
Internet
|
+-----+
| Web | App | Database |
+-----+
(Compromised Web exposes DB)
```

### ✓ Better Design (3-Tier Segmentation):

```
Internet → Public Subnet (ALB)
           ↓
           Application Subnet
           ↓
           Private Database Subnet
```

**Main Benefit:** Limits lateral movement. If one system is compromised, the attacker cannot easily pivot across the entire infrastructure.

## 8. Public vs Private Subnet ★★★★★

- **Public Subnet:** Designed for resources requiring direct internet connectivity via an Internet Gateway (e.g., Load Balancers, Bastion Hosts).
- **Private Subnet:** Designed for resources that must NOT be directly reachable from the public internet (e.g., Application servers, Databases).

## 9. VPN (Virtual Private Network)



A VPN creates an encrypted tunnel over an untrusted or public network (e.g., the Internet) to securely connect remote workers or offices to corporate cloud networks.

```
Without VPN: Employee ---- Internet ----> Cloud (Exposed / Unencrypted transit)
With VPN:    Employee —[ Encrypted VPN Tunnel 🔒 ]— Internet —> Company Cloud Network
```

**Why use VPN?** Secure remote access, encrypt traffic in transit, connect on-premises offices to cloud VPCs, and prevent eavesdropping/MitM attacks.

## MODULE 2: ZERO TRUST, IAM & GOVERNANCE

### 10 - 13. Zero Trust Architecture (ZTA) ★★★★★

**Traditional Perimeter:** "Users inside the corporate network are trusted."

**Zero Trust:** "Never trust automatically. Always verify explicitly."

#### Three Core Principles (Microsoft / NIST Framework):

1. **11. Verify Explicitly:** Always authenticate and authorize based on all available data points (Identity, Device Health, Location, Service/Workload, Data classification, and Anomaly telemetry).

User → Identity Check? → Device Posture? → Location/Risk? → Target Resource? → Access Decision

2. **12. Least Privilege:** Limit user access with Just-In-Time and Just-Enough-Access (JIT/JEA), risk-based adaptive policies, and data protection.

Developer Role —+— Read Logs ✓  
+— Deploy Application ✓  
+— Delete Production DB ✗ (Damage is strictly limited if account is breached)

3. **13. Assume Breach:** Minimize blast radius and segment access. Verify end-to-end encryption and use analytics to get visibility, drive threat detection, and continuously improve defenses.

Attacker Inside → Limited Privileges + Microsegmentation + Continuous Logging → Damage Minimized

### 14 - 16. MFA, RBAC & Privileged Access ★★★★★

#### 14. Multi-Factor Authentication (MFA) ★★★★★

Requires two or more distinct authentication categories:

- **1. Something you know:** Password, PIN, Secret Question
- **2. Something you have:** Smartphone, Authenticator OTP/Token, Hardware Smart Card, FIDO2 key
- **3. Something you are:** Biometrics (Fingerprint, Face recognition, Iris scan)

**Example: Password (Know) + OTP (Have) → MFA Verified → Access Granted**

#### 15. Role-Based Access Control (RBAC) ★★★★★

Permissions are assigned to *Roles* rather than individuals. Users inherit permissions by assuming roles.

User: Abhishek → Assigned Role: Developer → Inherits: Read Code, Deploy App (No DB Drop)

**Benefit: Simplifies auditing, standardizes permission management, and prevents privilege creep.**

#### 16. Privileged Access Management (PAM) ★★★★★

Privileged accounts (Cloud Admin, DBA, Root) carry extreme risk if compromised. Best practices include mandatory MFA, eliminating standing admin privileges, continuous session monitoring, and using Just-In-Time (JIT) elevation.

## MODULE 3: LOGGING, MONITORING & DISASTER RECOVERY

### 17 - 18. Logging, Monitoring & Incident Detection



Security is not only prevention—it requires real-time detection, alerting, and forensic capabilities.

User → Cloud Resource → Activity → Audit Log → SIEM Monitoring → Alert 🚨 → Security Team

**Log contents include:** Login attempts, API calls (CloudTrail), Permission changes, Resource creation/deletion, Network traffic flows (VPC Flow Logs).

#### Why Logging is Critical:

- Without Logs: Database deleted → Culprit unknown ❌
- With Logs: Database deleted → Identified User, Exact Timestamp, Origin IP, and API Method ✅

**Supports:** Real-time detection, forensic investigation, compliance auditing, incident response.

### 19 - 23. Backup, Disaster Recovery, RPO & RTO



**Backup:** A copy of data used for restoration after accidental deletion, hardware failure, ransomware, or corruption.

**Disaster Recovery (DR):** Strategies and processes to restore systems and services after a major disruption (region failure, natural disaster, cyberattack).

| Metric | Full Form                | Core Question                         | Focus Area          | Example                                                  |
|--------|--------------------------|---------------------------------------|---------------------|----------------------------------------------------------|
| RPO    | Recovery Point Objective | How much data loss can we tolerate?   | Data Loss (Time)    | RPO = 1 hr → Max 1 hour worth of data can be lost.       |
| RTO    | Recovery Time Objective  | How quickly must service be restored? | Downtime (Duration) | RTO = 30 min → System must be back online within 30 min. |

🧠 Memory Trick: RPO → Point in time (Data) | RTO → Time to restore (Downtime)

### 24 - 27. API Security, Auth & TLS



Mobile / Web App → [ HTTPS / TLS 🔒 ] → API Gateway (AuthN / AuthZ) → Backend Service → Database

#### 25. API Authentication ("Who are you?"):

Verifies identity using API keys, OAuth 2.0, JWT tokens, and mTLS.

#### 26. API Authorization ("What can you do?"):

Enforces permissions (e.g., User A can GET / profile, but DELETE /admin is Denied ❌).

**27. HTTPS / TLS** ★★★★★: Provides in-transit Confidentiality, Integrity, and Server Authentication over port 443.

## MODULE 4: ACCENTURE CLOUD SECURITY TIER 2 MCQS & DETAILED SOLUTIONS

Each question is accompanied by complete option analysis, verification notes, and key takeaways.

### Q1. What is the primary purpose of a cloud firewall?

- A. Encrypt stored data
- B. Control network traffic based on security rules
- C. Create database backups
- D. Authenticate users

✓ **Answer: B. Control network traffic based on security rules**

- A ✗ — Encryption protects data at rest/transit; it is not the primary purpose of a firewall.
- B ✓ — A firewall allows or blocks network traffic according to predefined security rules (IP, port, protocol).
- C ✗ — Backups are used for data recovery and disaster recovery.
- D ✗ — Authentication verifies identity; IAM handles this.

**Takeaway: Firewall = Network traffic inspection and control.**

### Q2. Which traffic is called inbound traffic?

- A. Traffic leaving a server
- B. Traffic entering a server/resource
- C. Traffic stored in a database
- D. Traffic encrypted using TLS

✓ **Answer: B. Traffic entering a server/resource**

- A ✗ — That is outbound (egress) traffic.
- B ✓ — Inbound (ingress) means traffic coming into a resource from external/internal sources.
- C ✗ — Stored data is data at rest, not network traffic.
- D ✗ — TLS is a cryptographic security protocol.

**Inbound = Incoming (IN) | Outbound = Outgoing (OUT)**

### Q3. Which statement correctly describes an AWS Security Group?

- A. It operates only at the physical data-center level
- B. It acts as a virtual firewall for associated resources
- C. It replaces IAM
- D. It is used only for database backups

✓ **Answer: B. It acts as a virtual firewall for associated resources**

- A ✗ — Physical infrastructure is managed exclusively by the cloud provider.
- B ✓ — Security Groups act as instance-level virtual firewalls controlling inbound/outbound traffic for resources like EC2 and ENIs.
- C ✗ — IAM manages user identity and permissions.
- D ✗ — Security Groups have no relation to backups.

**Security Group = Instance-level virtual firewall.**

**Q4. What is the major difference between a Security Group and a Network ACL?**

- A. Security Group operates at resource level; NACL operates at subnet level
- B. Security Group is used for encryption; NACL is used for hashing
- C. Both operate only at the physical server level
- D. NACL manages user passwords

✓ **Answer: A. Security Group operates at resource level; NACL operates at subnet level**

- A ✓** — Security Groups protect individual compute resources/ENIs; Network ACLs protect subnet boundaries.
- B ✗** — Neither is an encryption or hashing mechanism.
- C ✗** — Both are software-defined logical network security controls.
- D ✗** — Password management is handled by IAM and directory services.

**Security Group → Resource Level | NACL → Subnet Level**

**Q5. Which statement about a typical Security Group is correct?**

- A. It is stateful
- B. It is always stateless
- C. It only allows deny rules
- D. It operates only on physical routers

✓ **Answer: A. It is stateful**

- A ✓** — Security Groups are stateful: return traffic for an allowed inbound request is automatically allowed outbound regardless of outbound rules.
- B ✗** — Network ACLs are stateless, not Security Groups.
- C ✗** — Security Groups only support ALLOW rules (implicit deny by default).
- D ✗** — They are virtual cloud-native controls.

**Security Group → Stateful | NACL → Stateless**

**Q6. Which statement about a Network ACL is correct?**

- A. It operates at subnet level
- B. It operates only at user-account level
- C. It replaces authentication
- D. It encrypts database records

✓ **Answer: A. It operates at subnet level**

- A ✓** — NACLs control traffic entering and leaving VPC subnets.
- B ✗** — User account permissions are governed by IAM.
- C ✗** — NACLs are network packet filters, not authentication systems.
- D ✗** — Encryption protects stored data.

**Q7. Which security approach follows the principle "Never trust, always verify"?**

- A. Traditional perimeter security
- B. Zero Trust
- C. Backup strategy
- D. Load balancing

**✓ Answer: B. Zero Trust**

- A ✗** — Traditional perimeter models trust traffic once it crosses the internal network boundary.
- B ✓** — Zero Trust assumes all network locations are hostile and mandates explicit verification for every request.
- C ✗** — Backup strategy concerns disaster recovery.
- D ✗** — Load balancing distributes traffic.

**Q8. Which is NOT a core principle of Zero Trust?**

- A. Verify explicitly
- B. Use least privilege
- C. Assume breach
- D. Trust all internal users automatically

**✓ Answer: D. Trust all internal users automatically**

- A, B, C** — These are the three fundamental pillars of the Zero Trust security framework (Microsoft/NIST).
- D ✓** — Zero Trust strictly eliminates implicit trust based on network location or internal presence.

**Q9. A company gives a developer permission to read application logs but not delete them. Which principle is being applied?**

- A. Availability
- B. Least Privilege
- C. Network Address Translation
- D. Redundancy

**✓ Answer: B. Least Privilege**

- A ✗** — Availability ensures systems are accessible when needed.
- B ✓** — Least Privilege grants users only the specific permissions necessary to perform their job duties.
- C ✗** — NAT is a network IP translation mechanism.
- D ✗** — Redundancy provides fault tolerance.

**Q10. Which of the following is an example of MFA?**

- A. Username only
- B. Password only
- C. Password + OTP
- D. Security question only

**✓ Answer: C. Password + OTP**

- A, B ✗** — Single factor (Identification or single knowledge factor).
- C ✓** — Multi-Factor Authentication requires two distinct factor types: Password (something you know) + OTP (something you have).
- D ✗** — A security question alone is still a single knowledge factor.

**Q11. Which of the following is an example of "something you are"?**

- A. Password
- B. OTP
- C. Fingerprint
- D. PIN

**✓ Answer: C. Fingerprint**

**A, D ✗** — Something you know (Knowledge factor).

**B ✗** — Something you have (Possession factor).

**C ✓** — Biometrics such as fingerprints, facial geometry, and iris scans represent "something you are" (Inherence factor).

**Q12. What is the main purpose of RBAC?**

- A. Encrypt network packets
- B. Assign permissions based on user roles
- C. Create backups
- D. Detect DDoS attacks

**✓ Answer: B. Assign permissions based on user roles**

**A ✗** — Encryption protects data confidentiality.

**B ✓** — RBAC (Role-Based Access Control) assigns permissions to job roles rather than individuals, streamlining management.

**C ✗** — Backups protect against data loss.

**D ✗** — DDoS protection is handled by WAF/Shield services.

**Q13. An employee wants to securely access a company's private cloud network from home. Which technology is most appropriate?**

- A. VPN
- B. NACL
- C. Hashing
- D. Load Balancer

**✓ Answer: A. VPN**

**A ✓** — A VPN (Virtual Private Network) provides an encrypted tunnel over the public internet for secure remote access.

**B ✗** — NACLs control traffic at the subnet boundary inside the cloud.

**C ✗** — Hashing is an integrity verification mechanism.

**D ✗** — Load balancers distribute application traffic.

**Q14. What is the primary purpose of a VPN?**

- A. Increase CPU speed
- B. Create a protected/encrypted network connection
- C. Store passwords
- D. Replace IAM

**✓ Answer: B. Create a protected/encrypted network connection**

- A ✗** — VPNs introduce slight compute overhead for encryption/decryption.
- B ✓** — VPNs encapsulate and encrypt traffic to secure communication across untrusted networks.
- C ✗** — Password managers or secret managers store credentials.
- D ✗** — VPN does not replace identity management.

**Q15. Why is network segmentation important in cloud security?**

- A. It increases password complexity
- B. It limits lateral movement after a compromise
- C. It eliminates the need for encryption
- D. It replaces MFA

**✓ Answer: B. It limits lateral movement after a compromise**

- A ✗** — Password policies are managed via IAM/IdP.
- B ✓** — Isolating tiers (Web, App, DB) ensures that if an attacker breaches the frontend, they cannot directly access private backend databases.
- C ✗** — Defense-in-depth requires encryption regardless of segmentation.
- D ✗** — MFA is an authentication requirement.

**Q16. Which security mechanism is primarily used to detect suspicious activity?**

- A. Monitoring and logging
- B. Encryption
- C. Password hashing
- D. Load balancing

**✓ Answer: A. Monitoring and logging**

- A ✓** — Continuous logging and telemetry monitoring detect anomalies, unauthorized access, and security breaches.
- B ✗** — Encryption protects data confidentiality.
- C ✗** — Hashing secures credentials and ensures integrity.
- D ✗** — Load balancing enhances availability.

**Q17. Which information can commonly be found in security logs?**

- A. API calls
- B. Login attempts
- C. Resource changes
- D. All of the above

**✓ Answer: D. All of the above**

- A, B, C ✓** — Security audit trails capture API activity (e.g., AWS CloudTrail), authentication attempts, and infrastructure configuration changes.
- D ✓** — Therefore, all listed items are standard components of security logs.

**Q18. A company wants to restore its database after accidental deletion. Which security/recovery mechanism is most useful?**

- A. Backup
- B. MFA
- C. Firewall
- D. RBAC

✓ **Answer: A. Backup**

- A** ✓ — Backups store snapshot copies of data from which state can be restored after accidental deletion or corruption.
- B** ✗ — MFA prevents unauthorized access.
- C** ✗ — Firewalls filter network packets.
- D** ✗ — RBAC restricts unauthorized modifications.

**Q19. What does RPO primarily measure?**

- A. Maximum acceptable data loss
- B. Maximum number of users
- C. Maximum network bandwidth
- D. Authentication time

✓ **Answer: A. Maximum acceptable data loss**

- A** ✓ — RPO (Recovery Point Objective) determines the acceptable amount of data loss expressed backward in time from the moment of disruption.
- B, C, D** ✗ — These relate to system capacity, network throughput, and authentication latency.

**RPO → Data loss tolerance (Point in time)**

**Q20. A company's RTO is 30 minutes. What does this mean?**

- A. It can lose 30 minutes of data
- B. It should restore service within approximately 30 minutes
- C. Users must authenticate every 30 minutes
- D. The database backup runs every 30 minutes

✓ **Answer: B. It should restore service within approximately 30 minutes**

- A** ✗ — Data loss is defined by RPO.
- B** ✓ — RTO (Recovery Time Objective) defines the target duration within which systems and services must be fully restored after an outage.
- C** ✗ — Relates to session timeout.
- D** ✗ — Relates to backup frequency.

**RTO = Recovery Time / Allowable Downtime**

**Q21. Which HTTP-based protocol provides encrypted communication between a client and server?**

- A. HTTP
- B. HTTPS
- C. FTP
- D. Telnet

**✓ Answer: B. HTTPS**

- A ✗** — Plain HTTP transmits plaintext data (Port 80).
- B ✓** — HTTPS uses TLS encryption over Port 443 to secure HTTP traffic.
- C, D ✗** — FTP and Telnet are legacy protocols that transmit credentials in cleartext.

**Q22. What is the primary purpose of TLS in HTTPS?**

- A. Increase database storage
- B. Protect communication between client and server
- C. Assign user roles
- D. Create backups

**✓ Answer: B. Protect communication between client and server**

- A ✗** — TLS has no connection to storage capacity.
- B ✓** — TLS ensures confidentiality (encryption), integrity (tamper detection), and authenticity (server certificates) for client-server traffic.
- C ✗** — RBAC manages roles.
- D ✗** — Backup systems handle recovery.

**Q23. An API verifies that a request came from an authenticated user. Which concept is being applied?**

- A. Authentication
- B. Authorization
- C. Availability
- D. Segmentation

**✓ Answer: A. Authentication**

- A ✓** — Authentication is the verification of identity ("Who are you?").
- B ✗** — Authorization determines permissions and access rights ("What are you allowed to do?").
- C, D ✗** — Availability concerns uptime; segmentation isolates network resources.

**Q24. A user is authenticated but receives "Access Denied" when trying to delete an administrator account. What is primarily being enforced?**

- A. Authentication
- B. Authorization
- C. Encryption
- D. Availability

**✓ Answer: B. Authorization**

**A ✗** — The user's identity is already authenticated and confirmed.

**B ✓** — The system evaluated permissions and determined that the user is not authorized to delete administrative accounts.

**C, D ✗** — Encryption protects data; availability ensures uptime.

**| AuthN = Identity Verification | AuthZ = Permission Verification**

**Q25. Which architecture provides the BEST security isolation?**

- A. Internet → Database directly
- B. Internet → Database → Application
- C. Internet → Public Web Layer → Application → Private Database
- D. Internet → All resources in one public network

**✓ Answer: C. Internet → Public Web Layer → Application → Private Database**

**A ✗** — Exposing databases directly to the public internet creates extreme vulnerability.

**B ✗** — Databases must never sit in front of application layers.

**C ✓** — Multi-tier segmentation separates ingress from business logic and database layers, providing deep defense and preventing lateral attacks.

**D ✗** — Flat public networks maximize attack surface and blast radius.